

Name: Chougle Talha Zahoor Ahmed

Email id: tchougle60@gmail.com

College name: Royal College of Arts, Science and Commerce

1. Introduction

Soupedecode is a hands-on penetration testing challenge that focuses on **Active Directory exploitation**. The objective of this room is to compromise a **Domain Controller** by abusing common but critical weaknesses in enterprise environments.

This room emphasizes **real-world attack techniques**, including:

- Kerberos authentication abuse
- SMB enumeration
- Password spraying
- Pass-the-Hash attacks

Unlike traditional CTFs, this challenge simulates **realistic enterprise misconfigurations** and requires a structured attack methodology.

2. Objective of the Room

The main objectives of this room are:

- To enumerate an Active Directory environment
 - To identify valid domain users
 - To exploit weak authentication practices
 - To gain privileged access to the Domain Controller
 - To understand Kerberos- and SMB-based attack paths
-

3. Environment and Tools Used

Environment

- **Platform:** TryHackMe
- **Target:** Windows Domain Controller
- **Protocol Focus:** Kerberos, SMB

Tools Used

- nmap
 - smbclient / enum4linux
 - kerbrute
 - crackmapexec
 - impacket (for Pass-the-Hash)
-

4. Initial Enumeration

What was done

The first step was to identify exposed services on the target machine.

Tool Used

- Nmap

Command Used

```
nmap -sC -sV MACHINE_IP
```

Explanation & Logic

- -sC runs default scripts
- -sV detects service versions

This scan typically reveals:

- SMB (port 445)
- Kerberos (port 88)
- LDAP (port 389)

These services indicate an **Active Directory Domain Controller**.

5. SMB Enumeration

What was asked

Enumerate SMB shares and gather information from the domain.

Tools Used

- smbclient
- enum4linux

Commands Used

Enumerate SMB shares

```
smbclient -L //MACHINE_IP -N
```

Domain enumeration

```
enum4linux MACHINE_IP
```

Explanation & Logic

- SMB often allows anonymous or low-privileged access
 - Share names, domain users, and policies may be leaked
 - This step helps identify **valid usernames**
-

6. Kerberos User Enumeration

What was done

Kerberos was abused to determine **valid domain users**.

Tool Used

- **Kerbrute**

Command Used

```
kerbrute userenum -d soupedecode.local --dc MACHINE_IP users.txt
```

Explanation & Logic

- Kerberos responds differently for valid vs invalid users
 - This allows stealthy username enumeration
 - Usernames discovered here are used in later attacks
-

7. Password Spraying Attack

What was done

A password spraying attack was performed using a single password across multiple users.

Tool Used

- **CrackMapExec**

Command Used

```
crackmapexec smb MACHINE_IP -u users.txt -p Password123
```

Explanation & Logic

- Password spraying avoids account lockouts
 - Organizations often reuse weak passwords
 - Successful authentication confirms valid credentials
-

8. SMB Authentication and Privilege Validation

What was done

Confirmed access and checked privilege level.

Tool Used

- CrackMapExec

Command Used

```
crackmapexec smb MACHINE_IP -u USER -p PASSWORD --shares
```

Explanation & Logic

- Confirms SMB access
 - Reveals accessible shares
 - Helps determine if the account has elevated privileges
-

9. Pass-the-Hash Attack

What was done

Used NTLM hashes instead of plaintext passwords to authenticate.

Tool Used

- Impacket (psexec / wmiexec / smbexec)

Command Used

```
psexec.py DOMAIN/USER@MACHINE_IP -hashes <LM>:<NTLM>
```

Explanation & Logic

- NTLM hashes can be reused without cracking
 - Common in post-compromise scenarios
 - Allows command execution as the target user
-

10. Domain Controller Compromise

Outcome

Using the techniques above, privileged access to the **Domain Controller** was achieved.

This confirmed:

- Poor password hygiene
 - Kerberos enumeration exposure
 - SMB misconfigurations
 - Lack of credential protection
-

11. Key Learnings

- Kerberos can be abused for stealthy enumeration
 - Password spraying is highly effective in real environments
 - NTLM hashes are as powerful as plaintext passwords
 - SMB remains a critical attack surface
 - Domain Controllers are high-value targets
-

12. Conclusion

The **Soupedecode** room demonstrates how common enterprise misconfigurations can lead to **full domain compromise**. By chaining enumeration, Kerberos abuse, password spraying, and Pass-the-Hash techniques, a Domain Controller can be compromised without exploiting a single software vulnerability.

This room reinforces the importance of:

- Strong password policies
- Kerberos hardening
- SMB access control
- Credential hygiene

